Relazione Tecnica: Analisi dell'Impatto del Firewall sulla Superficie di Attacco

Studente: Antonio Oricchio

Data: 25/04/2026

Ambiente di test: VirtualBox (Rete Interna)

Macchina Target: Windows 10 (192.168.1.30)

Macchina Attaccante: Kali Linux (192.168.1.25)

1. Introduzione

L'obiettivo dell'esercitazione è verificare come la configurazione del Firewall di Windows influenzi i risultati di una scansione di rete effettuata con il tool nmap. Sono state analizzate le differenze nella visibilità dei servizi e la capacità del sistema di registrare tentativi di connessione non autorizzati.

2. Fase 1: Scansione con Firewall Disattivato

In questa fase, il Firewall di Windows è stato disabilitato tramite il comando:

netsh advfirewall set allprofiles state off

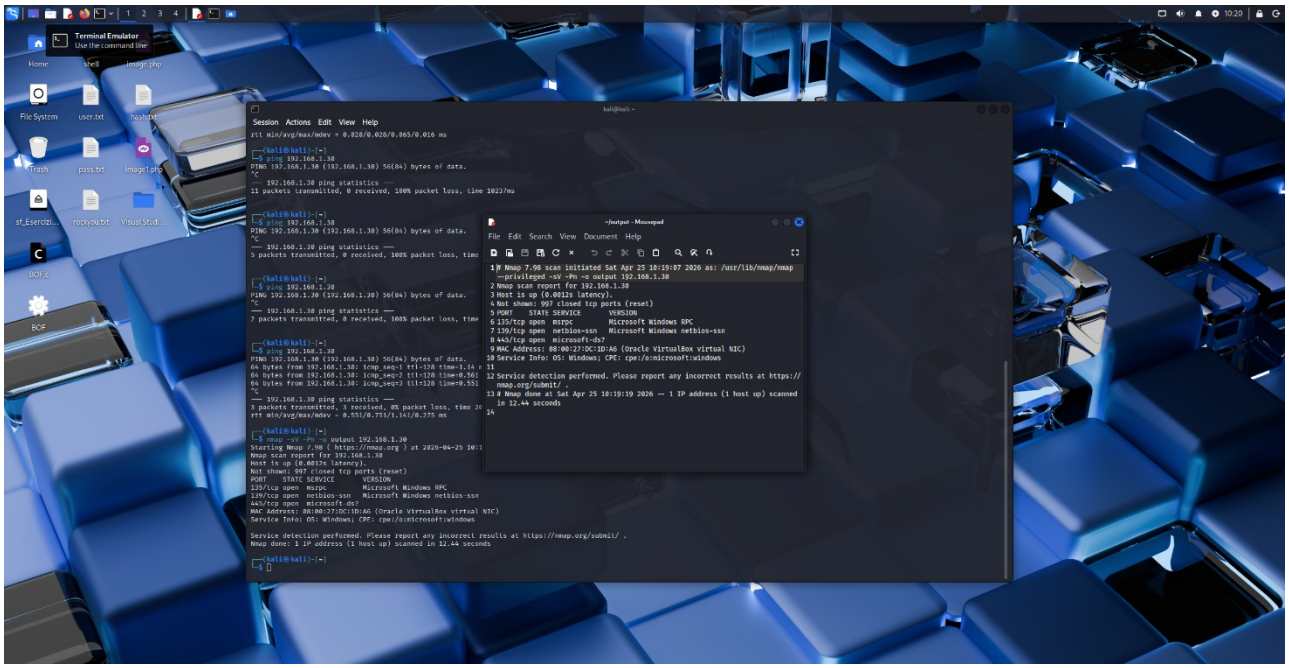
Comando di scansione eseguito su Kali:

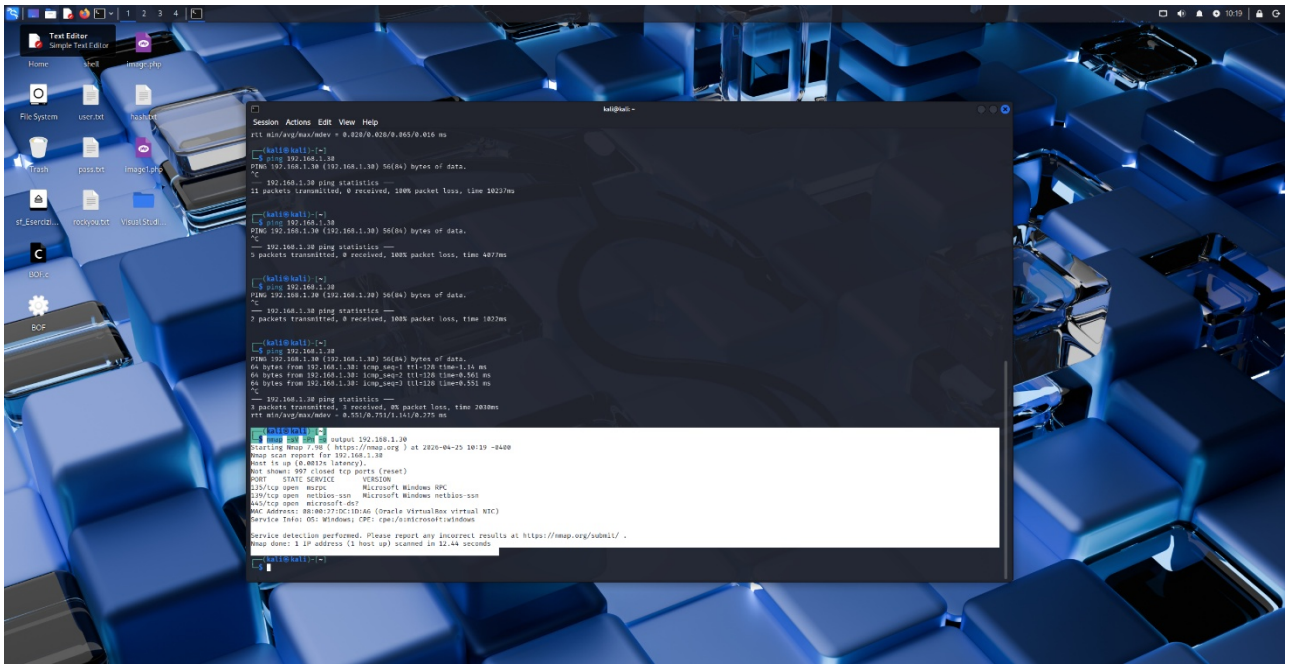
Bash

```
nmap -sV -o report_off 192.168.1.30
```

Risultati osservati:

- **Stato delle porte:** Molte porte (es. 135, 139, 445) risultano in stato open.
- **Service Detection:** Nmap è riuscito a identificare correttamente le versioni dei servizi (es. Microsoft Windows RPC, microsoft-ds).
- **Velocità:** La scansione è stata rapida poiché il target rispondeva immediatamente ai pacchetti SYN.





3. Fase 2: Scansione con Firewall Attivato

Il Firewall è stato riattivato tramite il comando:

netsh advfirewall set allprofiles state on

Comando di scansione eseguito su Kali:

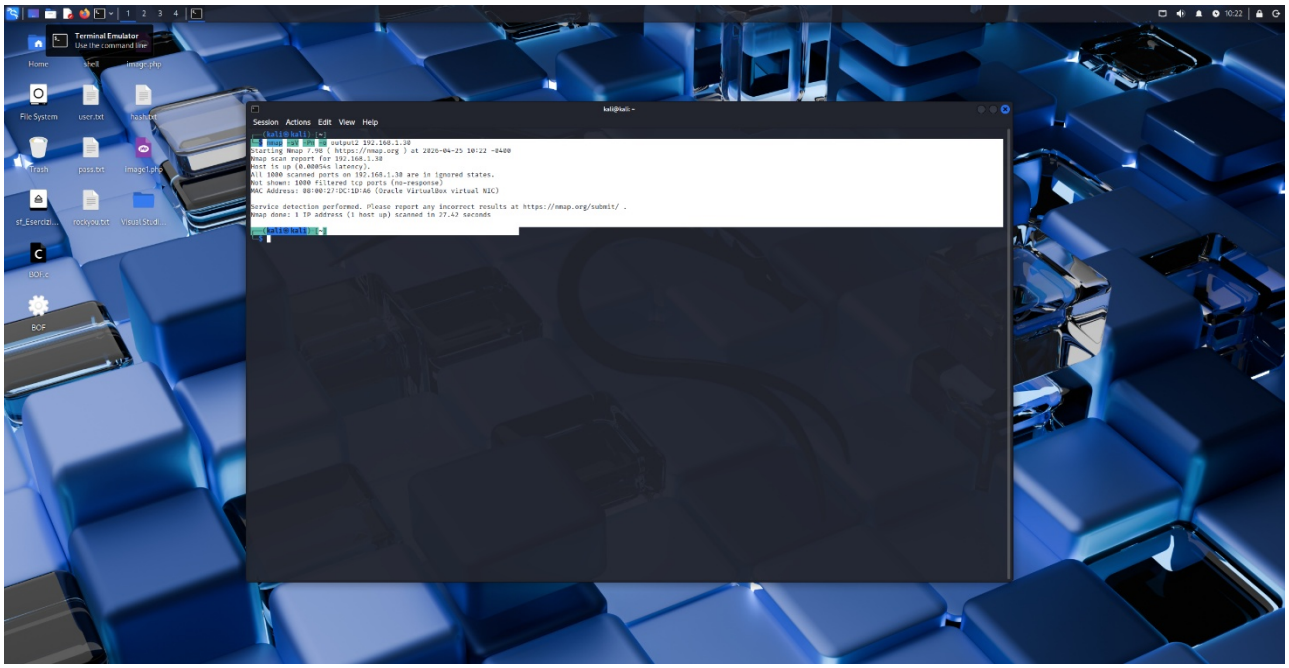
Bash

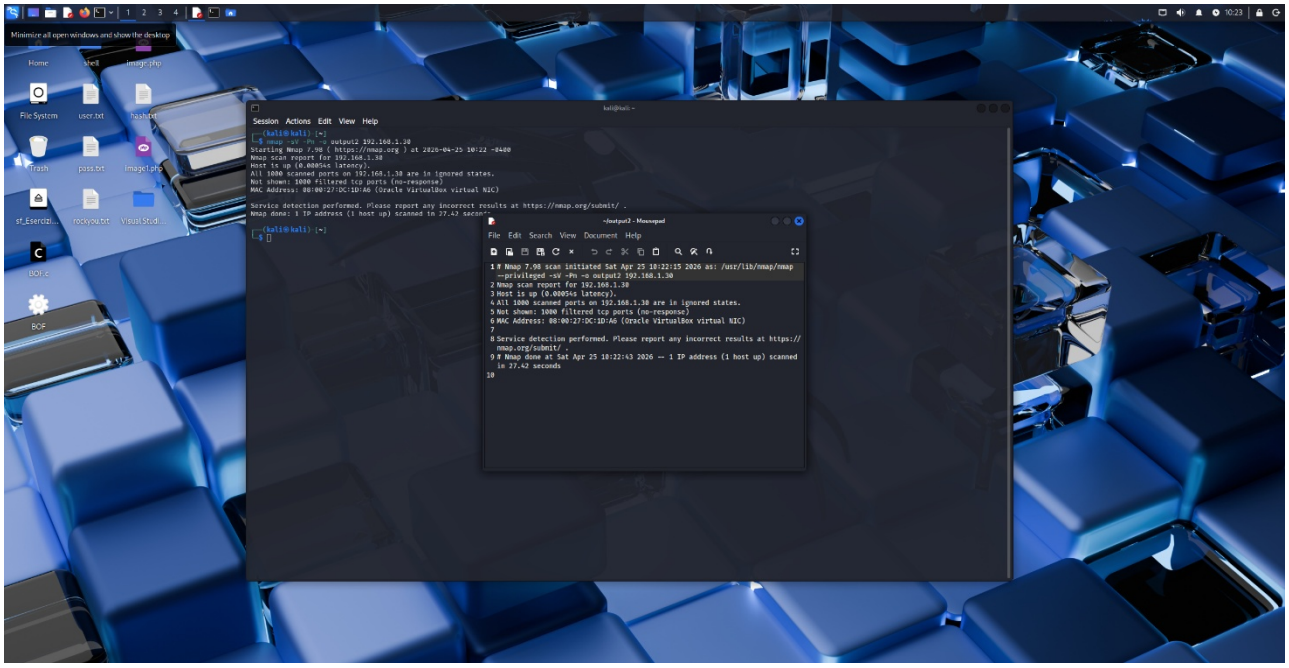
nmap -sV -Pn -o report_on 192.168.1.30

(Nota: è stato aggiunto lo switch -Pn perché il Firewall bloccava i pacchetti ICMP/Ping)

Risultati osservati:

- **Stato delle porte:** La quasi totalità delle porte è passata allo stato filtered.
- **Service Detection:** Nmap non è stato in grado di identificare le versioni dei servizi.
- **Velocità:** La scansione è risultata molto più lenta a causa dei timeout (attesa delle risposte mai arrivate).





4. Differenze e Motivazioni Tecniche

Elemento	Senza Firewall	Con Firewall
Visibilità	Massima (Porte open)	Minima (Porte filtered)
Risposta TCP	Invia pacchetti SYN/ACK o RST	Nessuna risposta (Packet Dropping)
Fingerprinting	Possibile e accurato	Impossibile

Motivazione: Quando il Firewall è attivo, esso opera una politica di **"Drop"**. Invece di rispondere con un pacchetto di reset (RST) per segnalare che una porta è chiusa, il Firewall scarta silenziosamente i pacchetti in entrata. Per nmap, l'assenza di risposta significa che non è possibile determinare se la porta sia aperta o chiusa, etichettandola quindi come "filtrata". Ciò riduce drasticamente le informazioni a disposizione di un attaccante.

5. Analisi dei Log (Facoltativo)

Per monitorare l'attività, è stata abilitata la registrazione dei pacchetti eliminati nelle proprietà avanzate del Firewall.

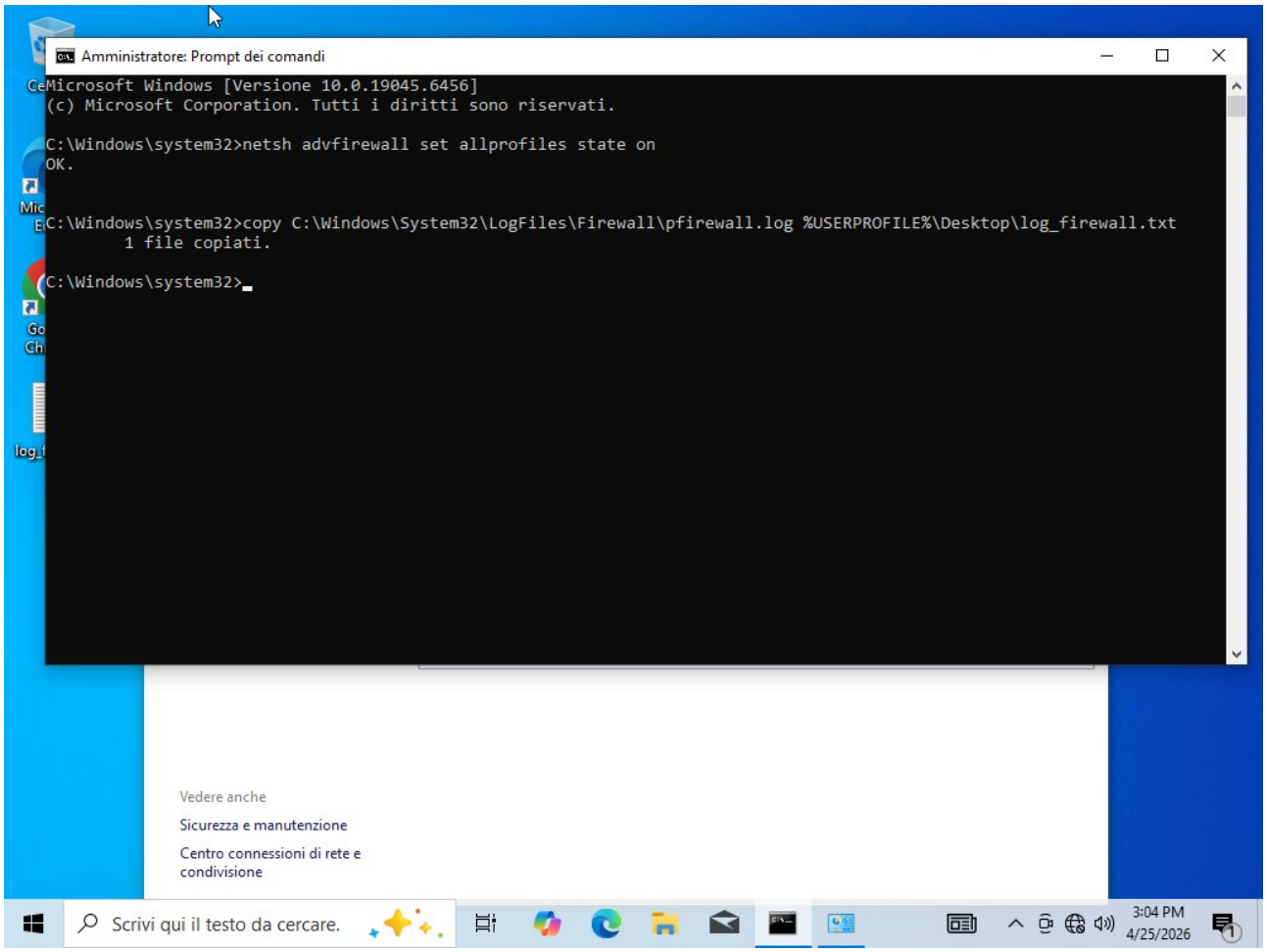
Log analizzati: C:\Windows\System32\LogFiles\Firewall\pfirewall.log

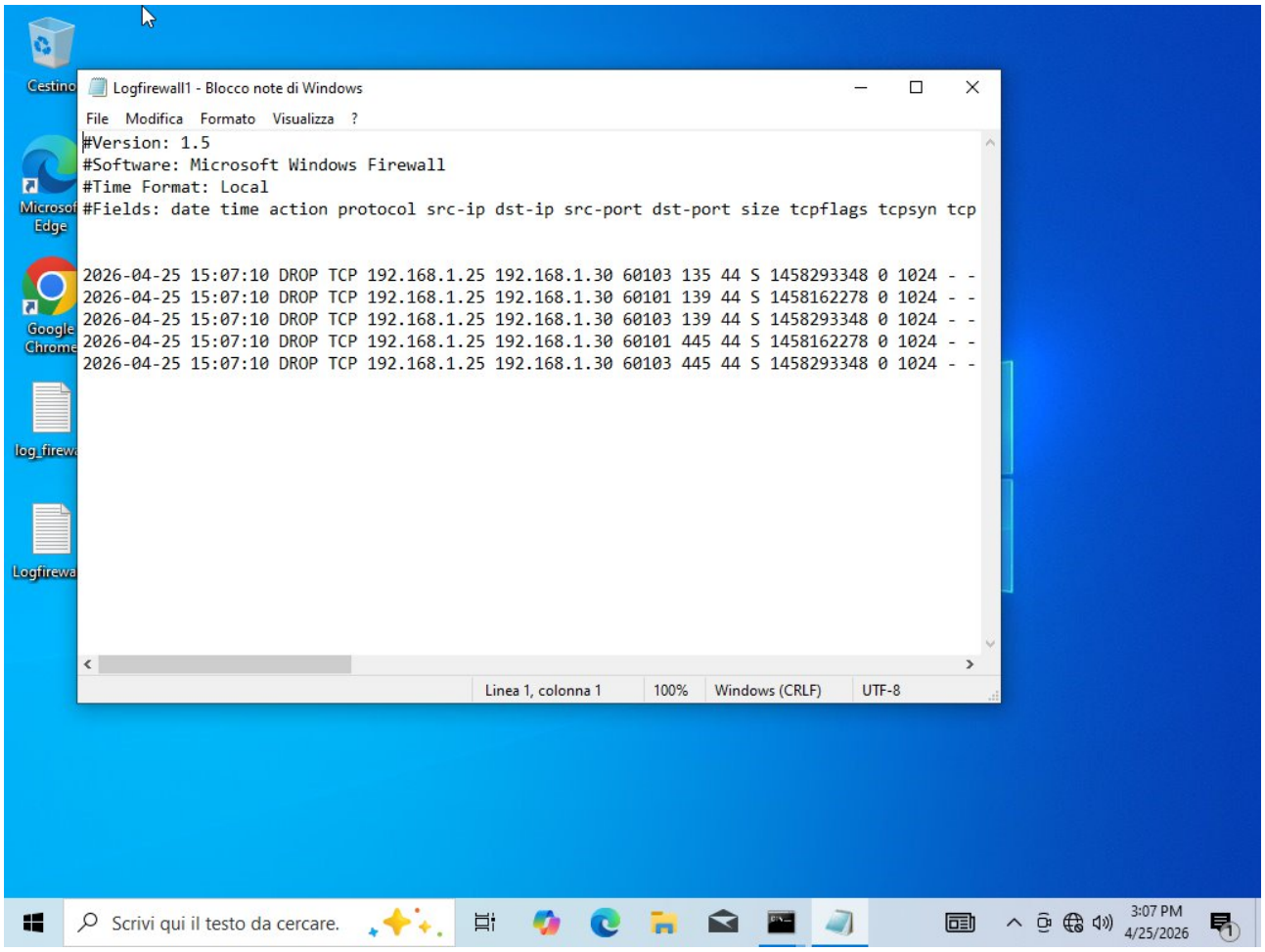
Cosa è stato trovato:

Il file di log ha registrato numerosi eventi di tipo **DROP**. Un esempio di riga estratta durante la scansione:

2026-04-25 16:30:05 DROP TCP 192.168.1.25 192.168.1.30 445 51234 ...

- **Identificazione:** Il log conferma che l'IP 192.168.1.25 (Kali) ha tentato di connettersi a diverse porte (es. 445) e che il Firewall ha intercettato e bloccato la connessione.
- **Utilità:** Questi log sono fondamentali in ambito di incident response per identificare tentativi di port scanning e l'origine di un potenziale attacco.


Amministratore: Prompt dei comandi
Microsoft Windows [Versione 10.0.19045.6456]
(c) Microsoft Corporation. Tutti i diritti sono riservati.
C:\Windows\system32>netsh advfirewall set allprofiles state on
OK.
C:\Windows\system32>copy C:\Windows\System32\LogFiles\Firewall\pfirewall.log %USERPROFILE%\Desktop\log_firewall.txt
1 file copiati.
C:\Windows\system32>
Vedere anche
Sicurezza e manutenzione
Centro connessioni di rete e condivisione
Scrivi qui il testo da cercare.
3:04 PM
4/25/2026



6. Conclusioni

L'esercizio dimostra che l'attivazione del Firewall è una misura di prevenzione primaria. Sebbene non elimini i servizi vulnerabili, li "nasconde" alla rete esterna, costringendo un eventuale attaccante a tentare tecniche più rumorose o complesse, e fornendo agli amministratori di sistema i log necessari per rilevare l'intrusione.

Esercizio extra

1. Definizioni: BC e DR

Business Continuity (BC)

La Business Continuity è l'insieme di processi, strategie e piani che permettono a un'organizzazione di continuare a erogare i propri servizi critici **durante e dopo** un evento

avverso. Non riguarda solo l'informatica, ma anche le persone, gli spazi fisici e la comunicazione.

- **Obiettivo:** "Restare in piedi" nonostante l'emergenza.

Disaster Recovery (DR)

Il Disaster Recovery è un sottoinsieme della Business Continuity che si concentra specificamente sull'infrastruttura tecnologica (ICT). Riguarda il ripristino di sistemi, dati, reti e applicazioni dopo un disastro che ne ha causato l'arresto.

- **Obiettivo:** "Tornare in funzione" nel minor tempo possibile dopo un crollo.

2. Tabella Comparativa: BC vs DR

Caratteristica	Business Continuity (BC)	Disaster Recovery (DR)
Focus	L'intera organizzazione (processi di business).	L'infrastruttura IT e i dati.
Obiettivo	Mantenere le operazioni minime attive durante la crisi.	Ripristinare i sistemi IT dopo un guasto.
Portata	Strategica (include HR, logistica, PR).	Tecnica (backup, server, repliche dati).
Pianificazione	Come lavorare senza certi sistemi o uffici.	Come ricostruire i sistemi informatici.
Indicatori Chiave	RTO (Recovery Time Objective).	RPO (Recovery Point Objective) e RTO.

3. ICT Readiness for Business Continuity (IRBC - ISO/IEC 27031)

Lo standard **ISO/IEC 27031** introduce il concetto di **IRBC** (*ICT Readiness for Business Continuity*). In passato, il Disaster Recovery era visto come un'attività "reattiva" (succede il disastro -> intervengo). L'IRBC sposta il focus sulla **proattività**.

Punti chiave della ISO 27031:

1. **Resilienza Digitale:** Non basta saper recuperare i dati; l'infrastruttura deve essere progettata per essere robusta e flessibile.
2. **Allineamento al Business:** I tempi di ripristino dell'IT devono essere dettati dalle necessità reali dell'azienda (non ha senso ripristinare il database marketing in 1 ora se la produzione può aspettare 24 ore).

3. **Il Ciclo PDCA:** Come ogni norma ISO, anche la 27031 segue il ciclo *Plan-Do-Check-Act* (Pianifica, Implementa, Verifica, Migliora) per garantire che la capacità di ripristino sia testata regolarmente e non resti solo un documento scritto.

4. Due concetti fondamentali da conoscere (RPO e RTO)

Per completare la tua comprensione della IRBC, devi conoscere questi due parametri tecnici:

- **RPO (Recovery Point Objective):** Indica la massima quantità di dati che l'azienda può permettersi di perdere (es. "RPO di 4 ore" significa che devo avere backup ogni 4 ore).
- **RTO (Recovery Time Objective):** Indica il tempo massimo necessario per tornare operativi (es. "RTO di 2 ore" significa che il sistema deve essere di nuovo online entro 2 ore dal guasto).